

Tema 8

Sarcină

1. Găsește un raport despre un atac cibernetic care implică activitățile grupării de infractori cibernetic **Carbanak/Anunak** (grup global asociat cu atacuri asupra instituțiilor financiare).
2. Analizează raportul găsit pentru a identifica indicatorii de vulnerabilitate și tacticile utilizate de această grupare.
3. Propune măsuri de optimizare și îmbunătățire a securității cibernetic pe baza tacticilor și vulnerabilităților identificate.

Introducere

Gruparea Carbanak, cunoscută și sub numele de Anunak, este una dintre cele mai sofisticate grupări de infractori cibernetic, specializată în atacuri asupra instituțiilor financiare. Între 2013 și 2015, Carbanak a furat peste 1 miliard de dolari prin utilizarea unor tehnici avansate precum spear-phishing, exploatarea vulnerabilităților software, mișcarea laterală în rețele și manipularea sistemelor critice. Aceste atacuri au avut un impact semnificativ la nivel global, vizând peste 100 de instituții din 30 de țări.

Scopul acestui raport este să analizeze tacticile folosite de Carbanak, să identifice vulnerabilitățile exploatare și să propună măsuri de securitate care pot preveni atacuri similare în viitor. În plus, raportul include o analiză detaliată a distribuției geografice a atacurilor și a momentelor de vârf ale activităților acestei grupări.

Conform raportului Kaspersky, activitățile grupării Carbanak s-au desfășurat la scară globală, cu o concentrație mare a mostrelor malware și victimelor în Rusia. Analiza de mai jos oferă o imagine clară asupra distribuției geografice a atacurilor și momentelor de activitate.

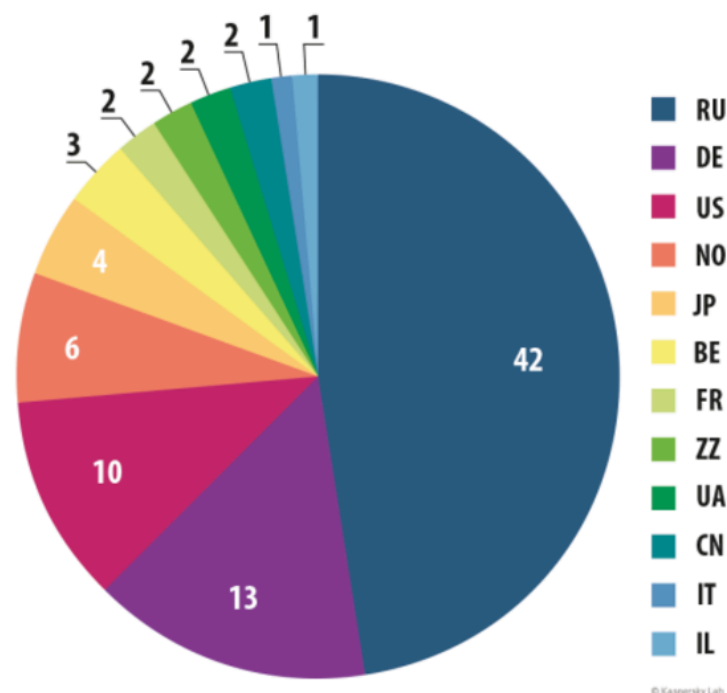


Fig 1. Distribuția geografică a mostrelor de malware Carbanak

Este evident că majoritatea atacurilor provin din Rusia, ceea ce sugerează că gruparea Carbanak își are originea sau operarea principală în această regiune. Prezența mostrelor din alte țări indică impactul global al acestui malware. Observăm că Rusia domină această distribuție cu 42% din mostrele identificate, urmată de Germania (13%), SUA (10%), și alte țări în procente mai mici.

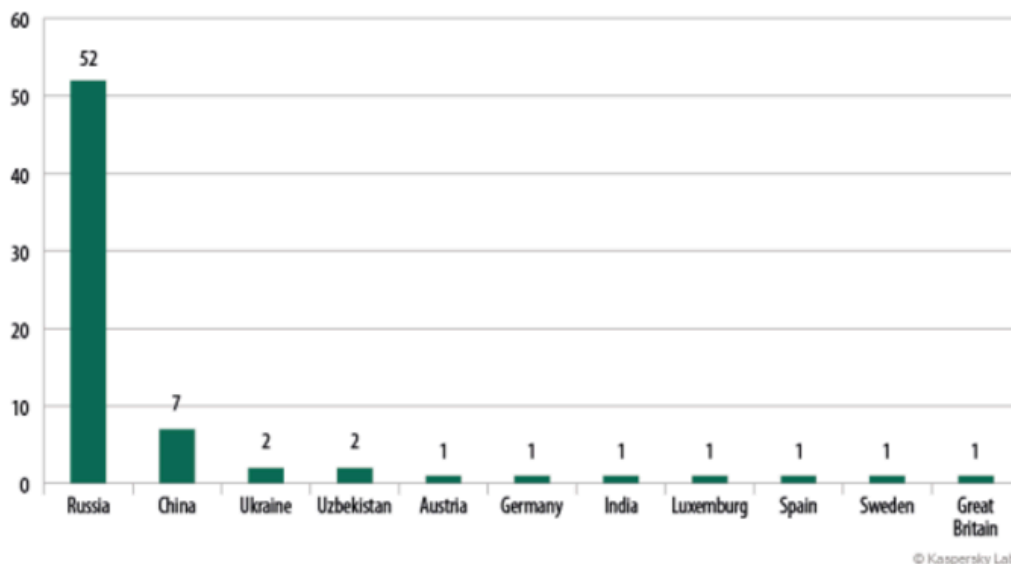


Fig 2. Distribuția geografică a victimelor

Graficul reprezintă distribuția victimelor, conform datelor Kaspersky Security Network (KSN). Rusia are cele mai multe victime (52%), urmată de China (7%) și alte țări cu procente mai mici.

Concentrarea victimelor în Rusia poate fi datorată băncilor și instituțiilor financiare slab protejate sau atacurilor specifice asupra instituțiilor din această regiune. De asemenea, ar putea reflecta o monitorizare mai bună a activităților locale de către Kaspersky.

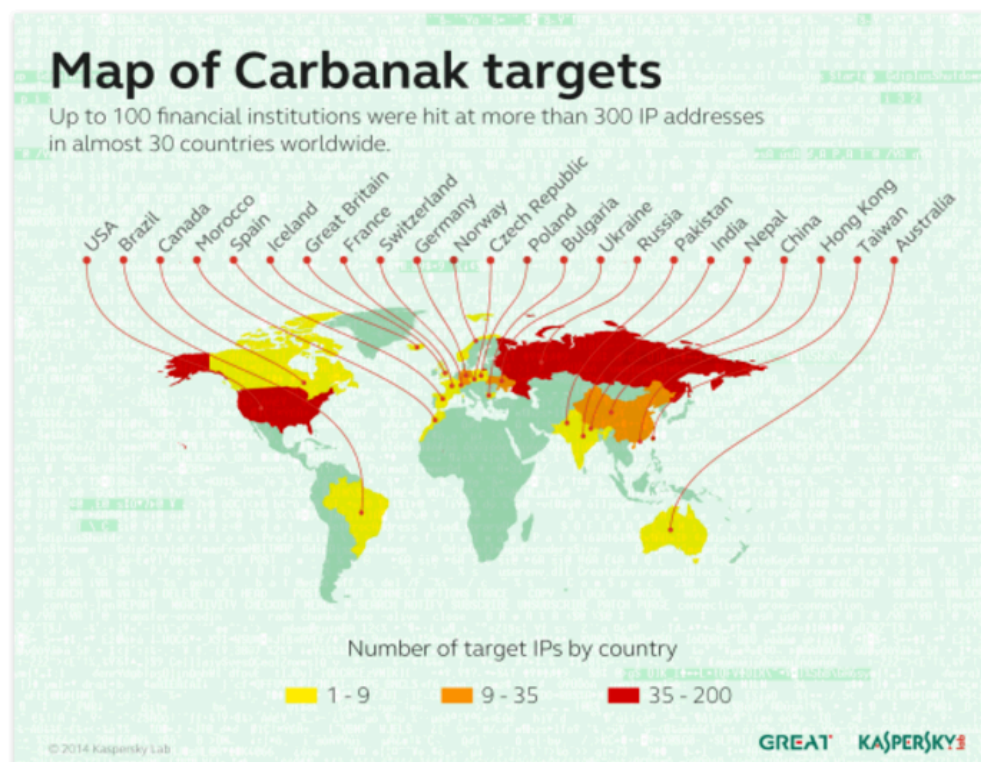


Fig 3. Harta globală a țintelor Carbanak

Imaginea reprezintă repartizarea globală a instituțiilor financiare vizate. Sunt evidențiate țări precum SUA, Rusia, Germania, și alte state europene și asiatice. Gruparea Carbanak a avut o acoperire globală, afectând instituții financiare din peste 30 de țări. Harta subliniază vulnerabilitatea băncilor la atacurile cibernetice bine coordonate.

Instituțiile financiare din țările vizate ar trebui să acorde prioritate implementării unor măsuri stricte de securitate.

Conform datelor culese de pe serverele de comandă și control (C2) ale grupării, Carbanak a vizat peste 100 de instituții financiare din 30 de țări. Cele mai afectate regiuni includ Rusia, SUA și Germania, dar și alte țări precum Ucraina, China și Franța.

Harta globală a atacurilor arată că gruparea a priorizat țările cu infrastructuri financiare sofisticate, dar cu lacune în protecția cibernetică. Acest lucru sugerează că tacticile lor au fost adaptate pentru a exploata vulnerabilitățile specifice fiecărei țări.

Indicatorii de vulnerabilitate identificați

Gruparea Carbanak/Anunak a exploatat o varietate de vulnerabilități tehnice și umane pentru a compromite instituțiile financiare și a obține acces la sisteme critice. Printre cele mai semnificative vulnerabilități identificate se numără:

- **Phishing și inginerie socială**

Carbanak a folosit spear-phishing ca metodă principală pentru a obține acces inițial în rețelele țintă. Acest tip de atac se bazează pe trimiterea de e-mailuri aparent legitime către angajați ai instituțiilor financiare. E-mailurile includeau atașamente malițioase (de exemplu, documente Word cu macro-uri periculoase) sau link-uri către site-uri care descărcau malware. Lipsa instruirii adecvate a angajaților în recunoașterea atacurilor de phishing a fost o vulnerabilitate majoră exploatată de grupare.

- **Lipsa actualizărilor software**

O altă vulnerabilitate esențială exploatată de Carbanak a fost utilizarea software-urilor neactualizate în instituțiile financiare. Gruparea a folosit vulnerabilități cunoscute în aplicații populare, precum Adobe Reader, Java sau Microsoft Office, pentru a instala malware. Absența unui sistem bine definit de patch management a permis atacatorilor să exploateze aceste breșe cunoscute.

- **Lipsa segmentării rețelei**

După compromiterea inițială a unui dispozitiv, atacatorii au profitat de rețelele slab segmentate pentru a se deplasa lateral și a obține acces la serverele critice. Lipsa separării dintre rețelele administrative și cele operaționale a permis atacatorilor să escaladeze privilegiile și să compromită sisteme sensibile, cum ar fi serverele care controlează bancomatele.

- **Utilizarea conturilor legitime compromise**

Un element esențial al succesului grupării Carbanak a fost utilizarea acreditărilor legitime furate ale angajaților. După compromiterea inițială, atacatorii au obținut parole și acces la conturi administrative prin instrumente precum Mimikatz. Lipsa autentificării multifactoriale (MFA) a facilitat accesul neautorizat la sisteme critice.

- **Utilizarea software-ului de control la distanță**

Atacatorii au utilizat software legitim de control la distanță, cum ar fi TeamViewer și AmmyyAdmin, pentru a gestiona infrastructurile compromise. Aceste programe, deși legitime, nu au fost monitorizate suficient de instituții, ceea ce a permis utilizarea lor pentru activități malițioase.

Tacticile utilizate de gruparea Carbanak

Carbanak a implementat un set complex de tactici avansate pentru a compromite și exploata țintele lor. Aceste tactici au inclus:

- **Acces inițial prin spear-phishing**

Gruparea a obținut acces inițial prin trimiterea de e-mailuri personalizate care păreau să provină de la surse de încredere. E-mailurile conțineau atașamente infectate sau link-uri care instalau malware odată accesate. Această metodă s-a bazat pe exploatarea neatenției angajaților și a lipsei de instruire în identificarea atacurilor de phishing.

- **Persistență în rețele**

Pentru a rămâne activi în rețelele țintă pe termen lung, atacatorii au instalat malware personalizat sub forma unui serviciu legitim de Windows. Această metodă a făcut dificilă detectarea activităților malițioase și le-a permis să mențină accesul chiar și după descoperirea unor componente ale atacului.

- **Escaladarea privilegiilor**

După accesul inițial, atacatorii au utilizat instrumente precum Mimikatz pentru a fura acreditările utilizatorilor și a obține acces la conturile administrative. Acest lucru le-a permis să dețină control complet asupra rețelelor și să acceseze resurse critice.

- **Mișcare laterală în rețea**

Carbanak a folosit instrumente precum PsExec pentru a se deplasa lateral în rețelele compromise. După compromiterea unui dispozitiv, atacatorii au explorat rețeaua pentru a găsi servere financiare, terminale bancare și alte sisteme critice.

- **Controlul bancomatelor**

O tactică inovatoare utilizată de Carbanak a fost programarea bancomatelor să elibereze numerar la anumite ore. Atacatorii au trimis comenzi către bancomate folosind accesul obținut la serverele bancare. Numerarul eliberat era colectat de complicii grupării.

Propuneri de optimizare și îmbunătățire a securității cibernetice

- **Instruirea angajaților**

Angajații reprezintă prima linie de apărare împotriva atacurilor cibernetice, iar lipsa lor de instruire în recunoașterea amenințărilor este o vulnerabilitate majoră. Prin urmare, instituțiile financiare trebuie să implementeze programe regulate de instruire care să îi ajute pe angajați să identifice e-mailurile de phishing și alte tehnici de

inginerie socială. Campaniile simulate de phishing pot fi un instrument eficient pentru a evalua nivelul de conștientizare al personalului și pentru a îmbunătăți răspunsurile acestora la potențiale atacuri. Prin testarea constantă și adaptarea instruirii în funcție de evoluția tacticilor infractorilor, se pot reduce semnificativ riscurile de acces inițial în rețea.

- **Implementarea unui sistem de patch management**

Un sistem riguros de patch management este esențial pentru a elimina vulnerabilitățile din software și hardware care ar putea fi exploatate de atacatori. Toate aplicațiile și sistemele de operare trebuie actualizate în mod regulat, folosind soluții automate pentru aplicarea patch-urilor. De exemplu, utilizarea Microsoft SCCM poate asigura că toate dispozitivele din rețea sunt la zi cu cele mai recente actualizări de securitate. Prin prevenirea exploatării vulnerabilităților cunoscute, instituțiile pot reduce drastic suprafața de atac.

- **Segmentarea rețelei**

Segmentarea rețelei este o metodă eficientă de limitare a mișcării laterale a atacatorilor. Prin separarea rețelelor critice, cum ar fi cele care controlează bancomatele, de rețelele administrative sau ale utilizatorilor obișnuiți, atacatorii nu vor putea accesa cu ușurință sistemele sensibile. Firewall-urile interne, regulile stricte de acces și utilizarea listelor de control al accesului (ACL) pot împiedica propagarea atacurilor în cazul unei breșe de securitate. Segmentarea reduce și expunerea datelor critice, ceea ce face mai dificilă realizarea unor atacuri complexe precum cele orchestrate de Carbanak.

- **Autentificare multifactorială (MFA)**

Autentificarea multifactorială este una dintre cele mai eficiente metode de prevenire a utilizării acreditărilor furate. MFA adaugă un strat suplimentar de securitate, cerând utilizatorilor să furnizeze mai mult decât o simplă parolă pentru a accesa sistemele critice. Implementarea MFA pentru toate conturile administrative și pentru sistemele sensibile, precum serverele bancare, poate împiedica atacatorii să utilizeze acreditările furate. Soluțiile precum Google Authenticator sau dispozitive hardware de autentificare, cum ar fi YubiKey, oferă un nivel ridicat de protecție împotriva accesului neautorizat.

- **Detectarea și răspunsul la incidente**

Monitorizarea activităților din rețea și detectarea timpurie a comportamentelor anormale sunt esențiale pentru a preveni escaladarea unui atac. Soluțiile de Endpoint Detection and Response (EDR) pot identifica și bloca activitățile suspecte, cum ar fi utilizarea instrumentelor de mișcare laterală precum PsExec. De exemplu, implementarea unor soluții precum CrowdStrike sau SentinelOne poate ajuta la

detectarea activităților neobișnuite în timp real și la oprirea atacurilor înainte ca acestea să producă daune semnificative.

- **Teste de penetrare periodice**

Simularea atacurilor cibernetice prin teste de penetrare poate ajuta instituțiile să identifice și să remedieze vulnerabilitățile înainte ca acestea să fie exploatare de infractori. Aceste teste ar trebui să includă scenarii complexe, cum ar fi spear-phishing, mișcare laterală și escaladarea privilegiilor. Angajarea unei echipe externe de testare poate oferi o perspectivă obiectivă asupra securității rețelei și poate identifica punctele slabe care necesită îmbunătățire.

Concluzii

Gruparea Carbanak a demonstrat capacitatea de a exploata atât vulnerabilitățile tehnice, cât și slăbiciunile umane pentru a compromite instituțiile financiare și a sustrage sume semnificative de bani. Activitățile lor au evidențiat lacune în securitatea cibernetică, cum ar fi lipsa instruirii angajaților, utilizarea software-urilor neactualizate, lipsa segmentării rețelelor și insuficiența metodelor de autentificare.

Implementarea măsurilor propuse, inclusiv instruirea angajaților, segmentarea rețelei, autentificarea multifactorială și monitorizarea traficului de rețea, poate contribui semnificativ la prevenirea atacurilor similare. În plus, testele de penetrare și soluțiile de detectare a incidentelor cibernetice pot asigura un răspuns rapid și eficient la potențialele amenințări.

Instituțiile financiare trebuie să înțeleagă că securitatea cibernetică nu este un proiect cu termen limitat, ci un proces continuu care necesită investiții, colaborare și adaptare constantă la noile amenințări. Astfel, implementarea unei strategii proactive poate minimiza riscurile și poate proteja infrastructura financiară împotriva unor grupări sofisticate precum Carbanak.